

Technical Decision TD_DBMS_B_001: Update to Role Definitions and Security Attribute Management for Consistency

Issue

Several Security Functional Requirements (SFRs) in the DBMS cPP, specifically FMT_MSA.1.1, FMT_REV.1.1(2), and FMT_SMR.1.1, contained inconsistencies regarding which roles may manage and revoke security attributes of users and objects. In particular, prior wording did not align the ability of "users with sufficient privileges" (per the Discretionary Access Control policy) with clearly defined roles in FMT_SMR.1, nor clarify distinctions between "users" and "objects" in these SFRs. This led to ambiguity and potential non-conformities for evaluations.

Resolution

To resolve the inconsistencies and clarify role definitions and allowable authority for managing and revoking security attributes, the following changes are adopted (effective immediately):

FMT_SMR.1.1

The TSF shall maintain the roles *[authorized administrator, authorized users, and [assignment: additional authorized identified roles]]*.

Application note: The new 'authorized users' role in SMR is referenced in FMT_REV.1.1(2) and FMT_MSA.1.1(2) (Objects)

FMT_MSA.1.1(1) (Users)

The TSF shall enforce the [Discretionary Access Control policy] to restrict the ability to [manage] the security attributes [associated with users] to [authorized administrators].

FMT_MSA.1.1(2) (Objects)

The TSF shall enforce the [Discretionary Access Control policy] to restrict the ability to [manage] the security attributes [associated with objects] to [authorized administrators, authorized users].

FMT_REV.1.1(2)

The TSF shall restrict the ability to revoke [assignment: list of security attributes] associated with objects under the control of the TSF to [the authorized administrator, authorized users].

FDP_ACC.1.1

The TSF shall enforce the [Discretionary Access Control policy] on [all subjects, all DBMS-controlled objects, and all operations among them].

Additional Clarification

- The term *authorized users* is explicitly added as a role in FMT_SMR.1.1 to resolve previous lack of alignment between roles cited in management and revocation SFRs.
- "Authorized users" in these SFRs replaces prior language such as "database users with sufficient privileges as allowed by the Discretionary Access Control policy."
- The distinction between managing/revoking attributes associated with users (administrators only) vs. those associated with objects (administrators and authorized users) is now made explicit.
- FDP_ACC.1.1 wording is updated to remove invalid refinements and to ensure access control provisions are neither limited nor ambiguous.

Rationale

These updates remove longstanding inconsistencies and ambiguities regarding role-based authority for security attribute management, enforcing clear, consistent, and evaluable requirements for both objects and users under the Discretionary Access Control Policy. Explicitly naming "authorized users" as a role aligns FMT_SMR, FMT_MSA, and FMT_REV, thereby ensuring conformity with CC standards and ease of evaluation. This alignment provides implementers, evaluators, and stakeholders with a precise framework for correct assignment and restriction of management privileges, in line with principle of least privilege and separation of duties.

Impact

- All evaluations against current versions of the DBMS cPP must follow these clarifications.
- Implementations and Security Targets must ensure that "authorized users" is defined as a role for appropriate SFRs and that policy documentation, guidance, and testing aligns accordingly.
- Evaluators must confirm that the assignment and enforcement of rights to manage and revoke security attributes of objects and users are implemented faithfully following these updated roles and SFR iterations.

This Technical Decision is effective immediately and shall be cited in all relevant cPP evaluations and corresponding SD evaluation activities.